

LEONARDO CORREA.

Informe de Seguridad Informática y Sistemas Operativos

1. Características de un Sistema Operativo Seguro

Según la información analizada y el criterio de diseño de sistemas, un sistema operativo seguro es aquel que garantiza que los recursos y datos solo sean accesibles y modificables por entidades autorizadas, protegiéndose de amenazas internas y externas. Sus características principales son:

- **Autenticación y Control de Acceso:** Validar sin lugar a dudas quién es el usuario y restringir sus acciones estrictamente a lo necesario.
- **Confidencialidad y Encriptación:** Los datos deben ser ilegibles para cualquiera que no tenga la clave de acceso, tanto en reposo (almacenados) como en tránsito.
- **Integridad y Disponibilidad:** Garantizar que la información no sea alterada de forma maliciosa o accidental, y que el sistema esté operativo y accesible para los usuarios legítimos cuando lo requieran.
- **Resiliencia y Trazabilidad:** Contar con copias de seguridad (backups) para recuperarse de desastres y un sistema de auditoría (logs) y monitoreo continuo para rastrear qué ocurrió, cuándo y quién lo hizo.
- **Mantenimiento Constante:** Un sistema seguro es un sistema actualizado; la gestión de parches evita que se exploten vulnerabilidades conocidas.

2. Seguridad a Nivel de Servidores y Justificación

La seguridad a nivel de servidores implica proteger la infraestructura central (hardware, software y red) donde residen los datos críticos y las aplicaciones de una organización.

- **Justificación:** El servidor es el "corazón" de la red. Un endpoint (como una laptop) comprometido afecta a un usuario; un servidor comprometido afecta a toda la empresa. Si un servidor cae, se pierde la **disponibilidad** de los servicios. Si es vulnerado, se pierde la **confidencialidad** e **integridad** de las bases de datos corporativas. Por ello, la seguridad en servidores requiere capas adicionales: firewalls estrictos, sistemas de detección de intrusos (IDS/IPS), control de acceso basado en el principio de mínimo privilegio y políticas de copias de seguridad automatizadas y aisladas.

3. Autenticación y Autorización en un Sistema Operativo

Aunque a menudo se confunden, son dos pasos secuenciales y distintos dentro de la gestión de identidades y accesos (IAM):

- **Autenticación ("¿Quién eres?"):** Es el proceso de verificar la identidad del usuario mediante credenciales. Puede ser algo que el usuario sabe (contraseña), algo que tiene (token o SMS), o algo que es (biometría).
- **Autorización ("¿Qué puedes hacer?"):** Ocurre *después* de la autenticación. Es el proceso que determina los permisos del usuario validado. El sistema operativo revisa sus políticas (como RBAC, MAC o DAC) para decidir si ese usuario tiene permitido leer, escribir o ejecutar un archivo o recurso específico.

4. Diferencias entre Virus, Gusano y Troyano

Todos son tipos de *malware* (software malicioso), pero se propagan y actúan de formas muy distintas:

Tipo de Malware	Método de Propagación	Intervención Humana	Objetivo Principal
Virus	Se adjunta a archivos o programas legítimos.	Sí. Requiere que el usuario ejecute el archivo infectado.	Corromper, modificar o destruir datos en el equipo infectado.
Gusano (Worm)	Explota vulnerabilidades de red para copiarse a sí mismo.	No. Se propaga automáticamente de un equipo a otro.	Consumir ancho de banda y replicarse masivamente, colapsando redes.
Troyano	Se camufla como un software legítimo o atractivo.	Sí. El usuario es engañado para instalarlo.	Crear "puertas traseras" (backdoors) para robar datos o permitir el control remoto del equipo.

5. Principios de Seguridad y Ejemplos

Los principios fundamentales se agrupan en la **Tríada CIA** (Confidencialidad, Integridad, Disponibilidad), a los que se suma el principio de acceso:

- **Confidencialidad:** Garantizar que la información no caiga en manos equivocadas.
 - *Ejemplo:* Enviar un correo con datos financieros de la empresa utilizando encriptación de extremo a extremo, de modo que si es interceptado, el atacante solo vea texto ilegible.
- **Integridad:** Mantener los datos exactos y completos, evitando modificaciones no autorizadas.

- *Ejemplo:* Un sistema bancario que utiliza funciones *hash* para asegurar que una transferencia de \$100 no sea alterada a \$10,000 durante el procesamiento.
- **Disponibilidad:** Asegurar que los sistemas y datos estén accesibles cuando se necesiten.
 - *Ejemplo:* Un hospital que tiene generadores eléctricos de respaldo y servidores redundantes para que el sistema de historial médico nunca deje de funcionar.
- **Principio del Mínimo Privilegio (PoLP):** Otorgar a un usuario solo los permisos estrictamente necesarios para su trabajo.
 - *Ejemplo:* Un pasante de marketing tiene acceso de "solo lectura" a las métricas de la web, pero no tiene privilegios de administrador para borrar la base de datos de clientes.

6. Estrategias ante un Ataque de Ransomware (Caso Práctico)

Contexto del incidente: Estás en la oficina. Un empleado recibe un enlace por mensaje de texto (SMS) en su teléfono corporativo, no verifica el remitente y, por descuido o desconocimiento, hace clic. Este ataque de *smishing* (phishing por SMS) descarga y ejecuta silenciosamente un ransomware que comienza a cifrar los archivos locales y busca expandirse por la red de la empresa.

Estrategias de respuesta y contención:

1. Aislamiento Inmediato (Contención):

- Desconectar el dispositivo del empleado de la red inmediatamente. Apagar el Wi-Fi, retirar el cable Ethernet y desconectar el Bluetooth. **No apagar el equipo**, ya que se podría perder información valiosa en la memoria RAM para el análisis forense, pero sí aislarlo para evitar el movimiento lateral del ransomware hacia los servidores.

2. Notificación y Triage:

- El empleado debe notificar de inmediato al departamento de TI o al Centro de Operaciones de Seguridad (SOC). No se debe intentar borrar archivos por cuenta propia.

3. Evaluación de Daños y Bloqueo:

- El equipo de TI identificará qué tipo de ransomware es y bloqueará la cuenta del usuario infectado en el Directorio Activo (Active Directory) para revocar su autorización y frenar el cifrado en carpetas compartidas de la red.

4. Recuperación (No pagar el rescate):

- Aplicar el principio de **Copias de seguridad y Disponibilidad**. Formatear el dispositivo comprometido, reinstalar el sistema operativo seguro de cero y restaurar los datos desde el último backup offline limpio. Nunca se debe pagar el rescate, ya que no garantiza la recuperación y fomenta la ciberdelincuencia.

5. Análisis Post-Incidente y Mitigación Futura:

- Auditar los *logs* (monitoreo) para entender exactamente qué vulnerabilidad se explotó.
- **Educación:** Como el fallo fue humano ("le da clic sin saber"), la estrategia a largo plazo más efectiva es impartir capacitación obligatoria sobre concientización en ciberseguridad para enseñar a la plantilla a identificar phishing y smishing.